

ЛЕКЦИЯ 10

Защитни стени

доц д-р инж. Росен Радков

МРЕЖОВО АДМИНИСТРИРАНЕ

Какво е защитна стена (firewall)?

- **Защитната стена** е средство за защита на локална система или мрежа от системи от мрежови заплахи за сигурността. Конфигурацията им по подразбиране включва разделяне на компютърната мрежа на две зони – публична (*untrusted network*) и частна (*trusted network*) и действието им по подразбиране се свежда до разрешаване на изходящия трафик и блокиране на непоискания входящ трафик;
- **Защитната стена** е софтуер, който се изпълнява върху специализиран хардуер или хардуер с общо предназначение;

МРЕЖОВО АДМИНИСТРИРАНЕ

Какво е защитна стена (firewall)?

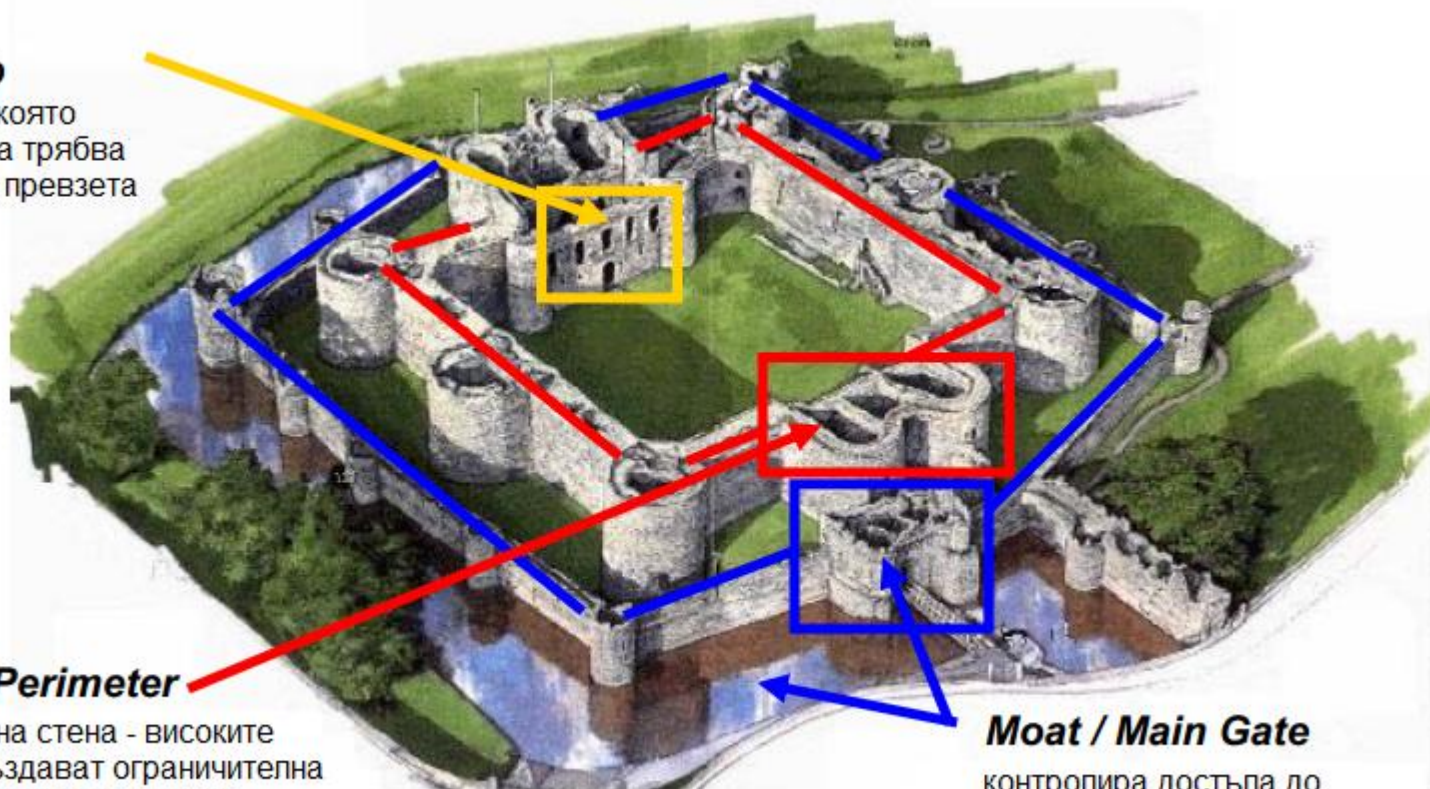
- **Защитната стена** е средство реализиращо част от политиката за сигурност на организацията, свързано с организиране на защитата на периметъра на компютърната мрежа, както и на критичните ресурси;

МРЕЖОВО АДМИНИСТРИРАНЕ

Какво е защитна стена (firewall)?

Keep
сграда, която
последна трябва
да бъде превзета

Inner Perimeter
крепостна стена - високите
стени създават ограничителна
зона между вътрешния и
външен периметър

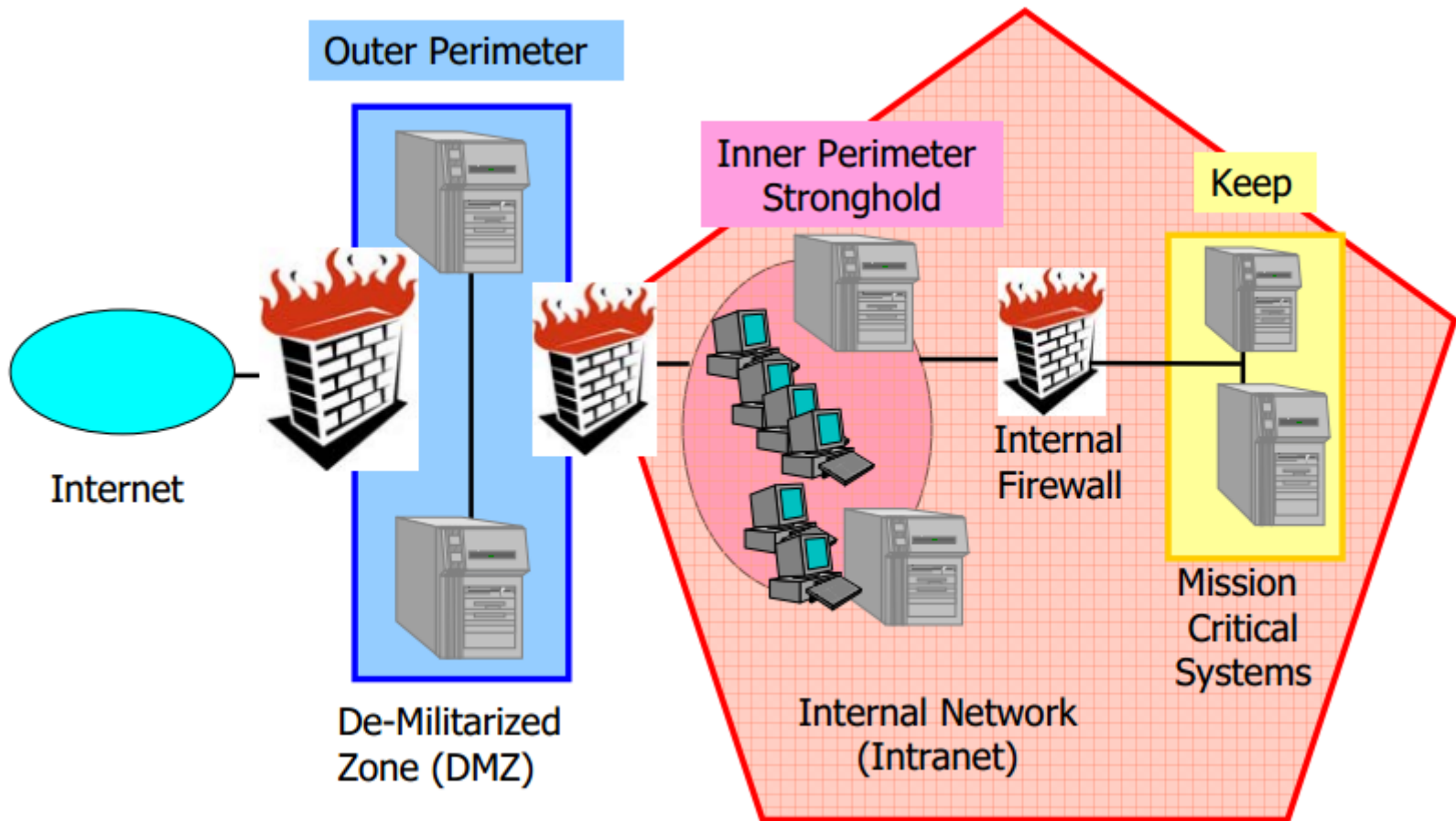


Moat / Main Gate
контролира достъпа до
крепостта

доц д-р инж. Росен Радков

МРЕЖОВО АДМИНИСТРИРАНЕ

Какво е защитна стена (firewall)?



доц д-р инж. Росен Радков

МРЕЖОВО АДМИНИСТРИРАНЕ

Какво е защитна стена (firewall)?

➤ Какво **МОЖЕ** защитната стена?

- Да приложи политика за сигурност в една точка;
- Да инспектира трафика според конкретен набор от негови характеристики и да блокира при необходимост, неразрешения от наложената политика за сигурност трафик, както и да записва събитията свързани с него;
- Позволява прилагането на строга автентикация;
- Може да осигури прилагането на IPSec за изграждане на VPN;

доц д-р инж. Росен Радков

МРЕЖОВО АДМИНИСТРИРАНЕ

Какво е защитна стена (firewall)?

➤ Какво **НЕ МОЖЕ** защитната стена?

- Да предпази от атаки, чийто трафик не преминава през нея;
- Да предпази от вътрешни заплахи свързани с действия на служители;
- Да предпази от вируси, които са внесени чрез заразени вън от организацията компютри;
- Да предпази от проникване, чрез лошо защитени безжични мрежи, чиито трафик не се инспектира от тях;

МРЕЖОВО АДМИНИСТРИРАНЕ

Технологии за изграждане на защитна стена

➤ *Packet filtering firewalls*

- Без следене на състоянието на връзките (*stateless*) – всеки пакет се разглежда индивидуално;
- Със следене на състоянието на връзките (*statefull*) – пакетите се групират във връзки;

➤ *Circuit level gateways*

➤ *Application gateways* (или прокси сървъри)

МРЕЖОВО АДМИНИСТРИРАНЕ

Технологии за изграждане на защитна стена

◆ *Packet filtering firewalls (stateless)*

Филтриращите правила се създават на базата на характеристиките, които се съдържат в заглавните части на:

- ✓ IP пакета (Source IP address, Destination IP address, Protocol);

и

- ✓ TCP сегмента/UDP дейтаграмата (TCP/UDP port);

МРЕЖОВО АДМИНИСТРИРАНЕ

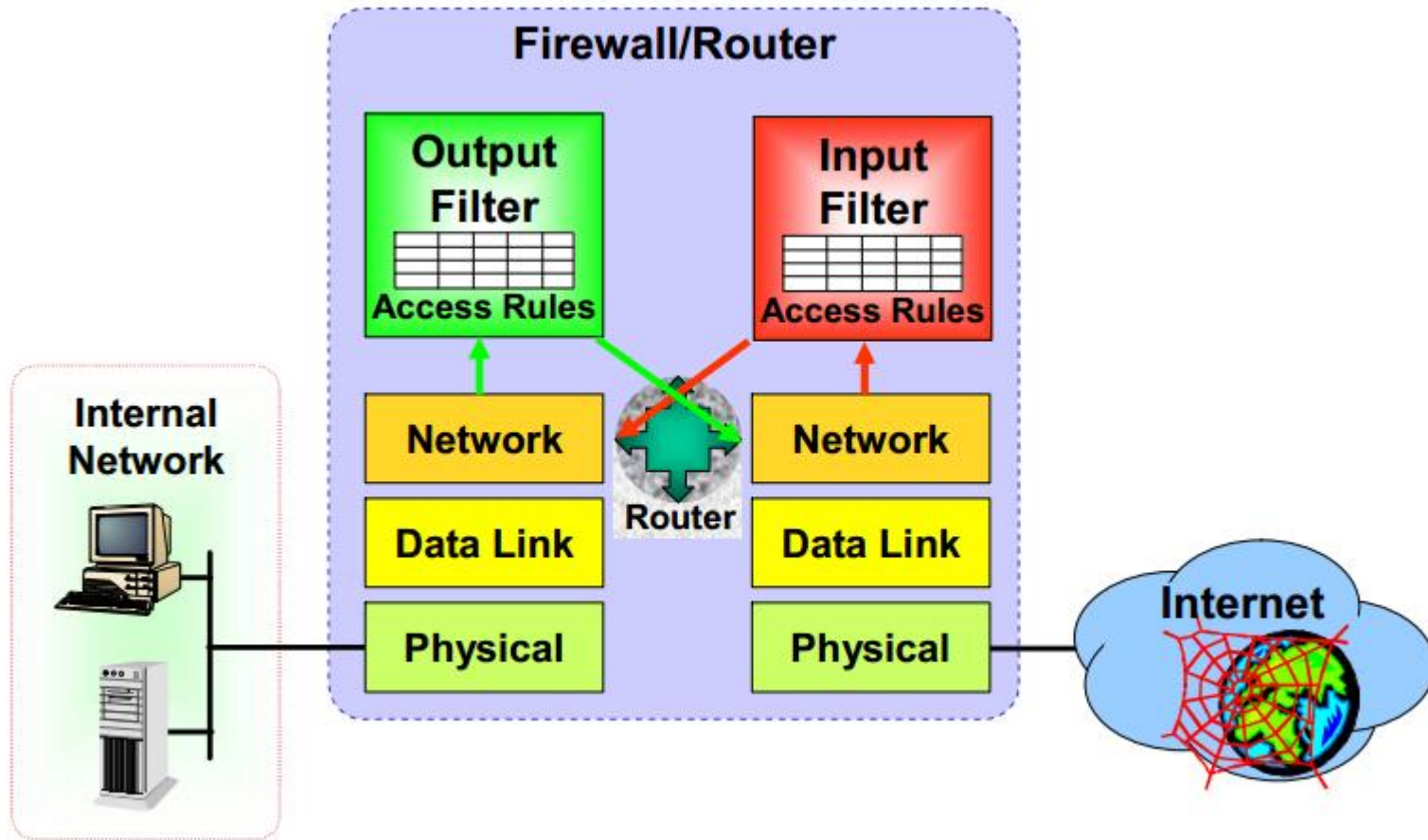
Технологии за изграждане на защитна стена

Rule	Direction	Source Address	Destination Address	Protocol	# Source Port	# Destin. Port	Action
1	Out	*	10.56.199*	*	*	*	Drop
2	Out	10.56*	10.122*	TCP	*	23 (Telnet)	Pass
3	In	10.122*	10.56.199*	TCP	23 (Telnet)	*	Pass
4	In & Out	*	10.56.199*	TCP	*	25 (Mail)	Pass
5	In	*	*	TCP	*	513 (rlogin)	Drop
6	In	201.32.4.76	*	*	*	*	Drop
7	Out	*	*	TCP	*	20 (FTP)	Pass
8	In	*	10.56.199*	TCP	*	20 (FTP)	Drop

доц д-р инж. Росен Радков

МРЕЖОВО АДМИНИСТРИРАНЕ

Технологии за изграждане на защитна стена



доц д-р инж. Росен Радков

МРЕЖОВО АДМИНИСТРИРАНЕ

Технологии за изграждане на защитна стена

Пример за политики:

<u>Policy</u>	<u>Firewall Setting</u>
No outside Web access.	Drop all outgoing packets to any IP address, port 80
No incoming TCP connections, except those for institution's public Web server only.	Drop all incoming TCP SYN packets to any IP except 130.207.244.203, port 80
Prevent Web-radios from eating up the available bandwidth.	Drop all incoming UDP packets - except DNS and router broadcasts.
Prevent your network from being used for a smurf DoS attack.	Drop all ICMP packets going to a "broadcast" address (eg 130.207.255.255).
Prevent your network from being tracerouted	Drop all outgoing ICMP TTL expired traffic

доц д-р инж. Росен Радков

МРЕЖОВО АДМИНИСТРИРАНЕ

Технологии за изграждане на защитна стена

◆ *Packet filtering firewalls (stateless)*

✓ Предимства:

- опростена архитектура;
- ниска цена;
- висока скорост на обработката (филтрирането);

✓ Недостатъци:

- използва малък брой параметри за филтриране;
- не може да прави инспекция на приложните протоколи;
- не поддържат строга автентикация;
- уязвими са на атаки свързани с TCP/IP протоколите;

МРЕЖОВО АДМИНИСТРИРАНЕ

Технологии за изграждане на защитна стена

◆ *Packet filtering firewalls (statefull)*

- Следи статуса на всяка TCP връзка (SYN, FIN) и се взема решение в контекста на връзката;
- Следи се таймаут на връзката

Source address	Source port	Destination Address	Destination port	Connection state
192.168.1.100	1030	210.9.88.29	80	established
192.168.1.102	1031	216.32.42.123	25	established

МРЕЖОВО АДМИНИСТРИРАНЕ

Технологии за изграждане на защитна стена

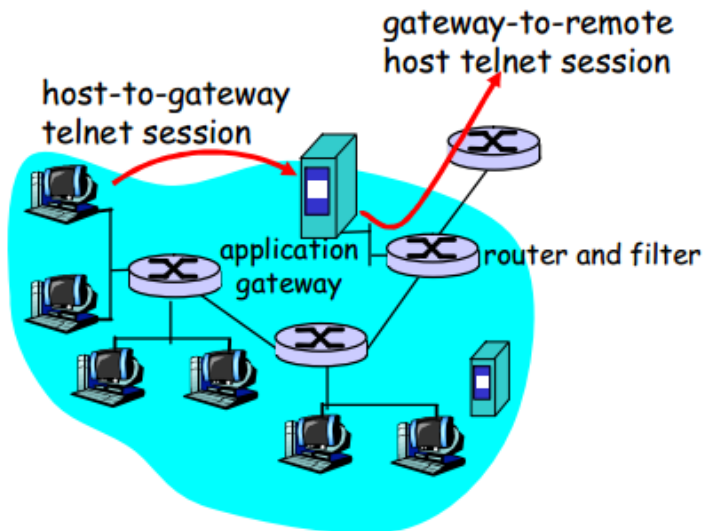
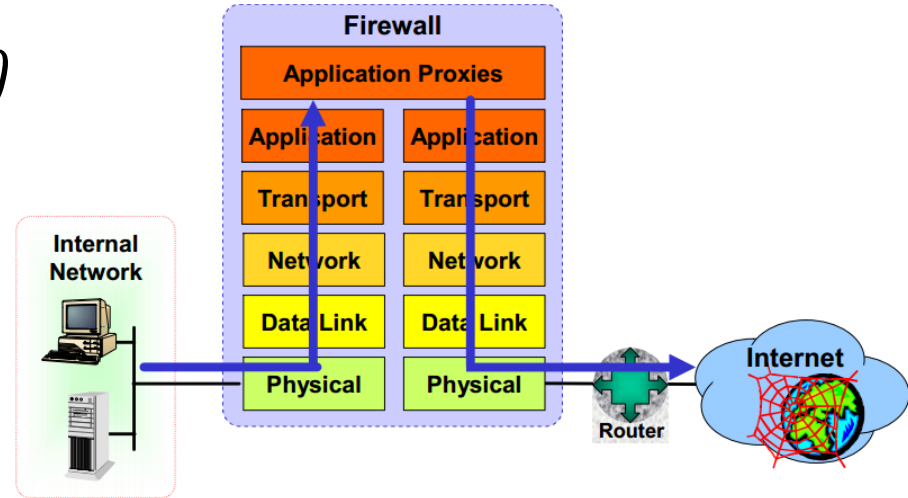
◆ *Application Gateways (AG)*

- ✓ Работят на приложния слой на TCP/IP модела, като не допускат връзка от край-до-край на ниво приложен протокол;
- ✓ Функцията им се състои в това да определят коя връзка е легитимна и трябва да бъде разрешена;
- ✓ Предоставят възможност да бъдат кеширани данни (прокси сървъри);
- ✓ Обикновено поддържат само един протокол;

МРЕЖОВО АДМИНИСТРИРАНЕ

Технологии за изграждане на защитна стена

◆ *Application Gateways (AG)*



1. Всички ползват telnet само през AG
2. За легитимните потребители, AG изгражда връзка до отдалечения хост
3. рутера блокира всички telnet връзки, които не са инициирани от AG

доц д-р инж. Росен Радков

МРЕЖОВО АДМИНИСТРИРАНЕ

Технологии за изграждане на защитна стена

◆ *Application Gateways (AG)*

✓ Предимства:

- откриват заплахи, вложени в приложните протоколи;
- дават възможност за детайлно логване на ниво приложен протокол;
- по-сигурен от пакетните филтри;

✓ Недостатъци:

- по-сложна архитектура;
- необходим е по-мощен хардуер;
- по-висока цена;

МРЕЖОВО АДМИНИСТРИРАНЕ

Технологии за изграждане на защитна стена

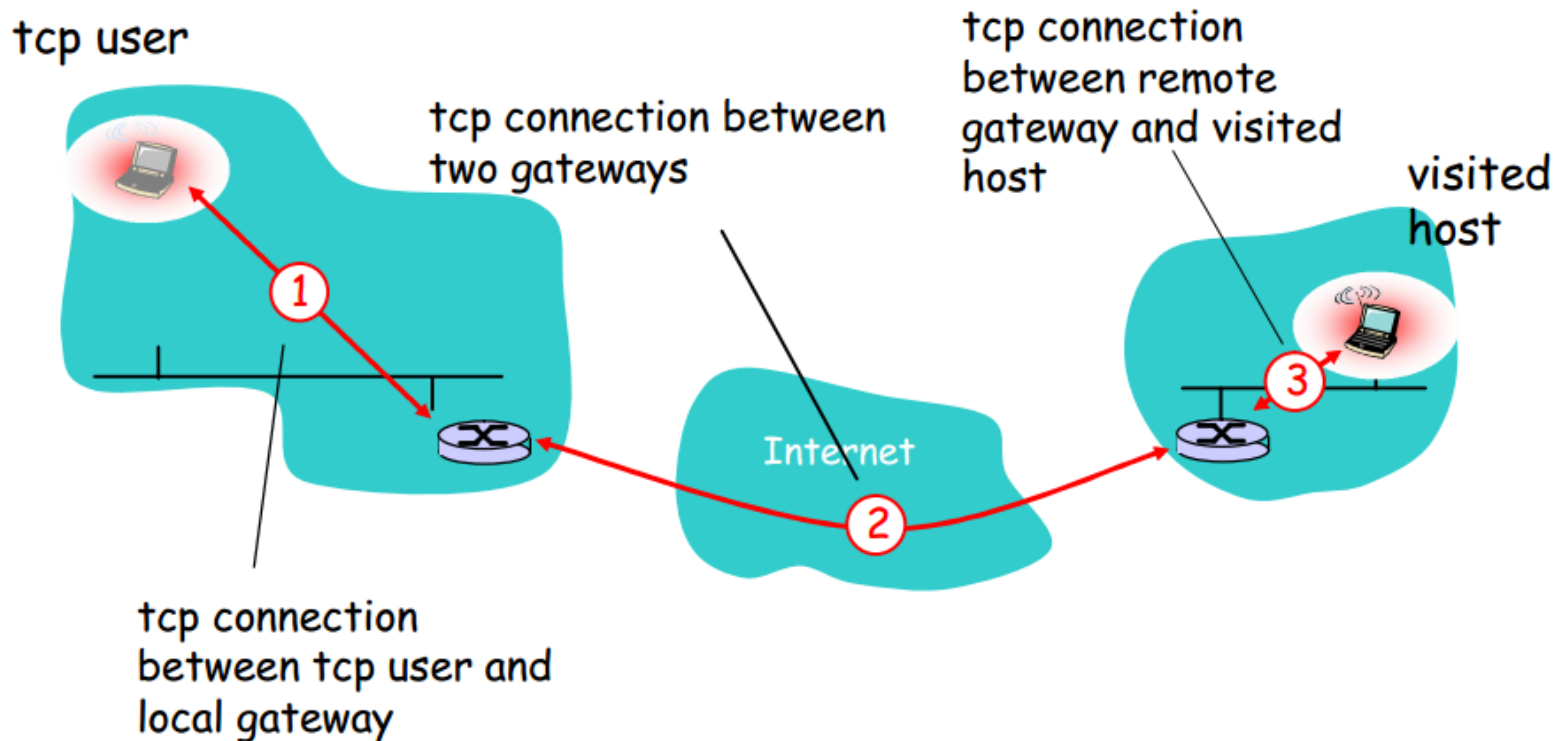
◆ *Circuit Level Gateways (CLG)*

- ✓ Работят на транспортния слой на TCP/IP модела, като не допускат TCP връзка от край-до-край;
- ✓ Функцията им се състои в това да определят коя връзка е легитимна и трябва да бъде разрешена;
- ✓ След изграждане на връзките client-CLG и CLG-client, TCP сегментите се предават без проверка;

МРЕЖОВО АДМИНИСТРИРАНЕ

Технологии за изграждане на защитна стена

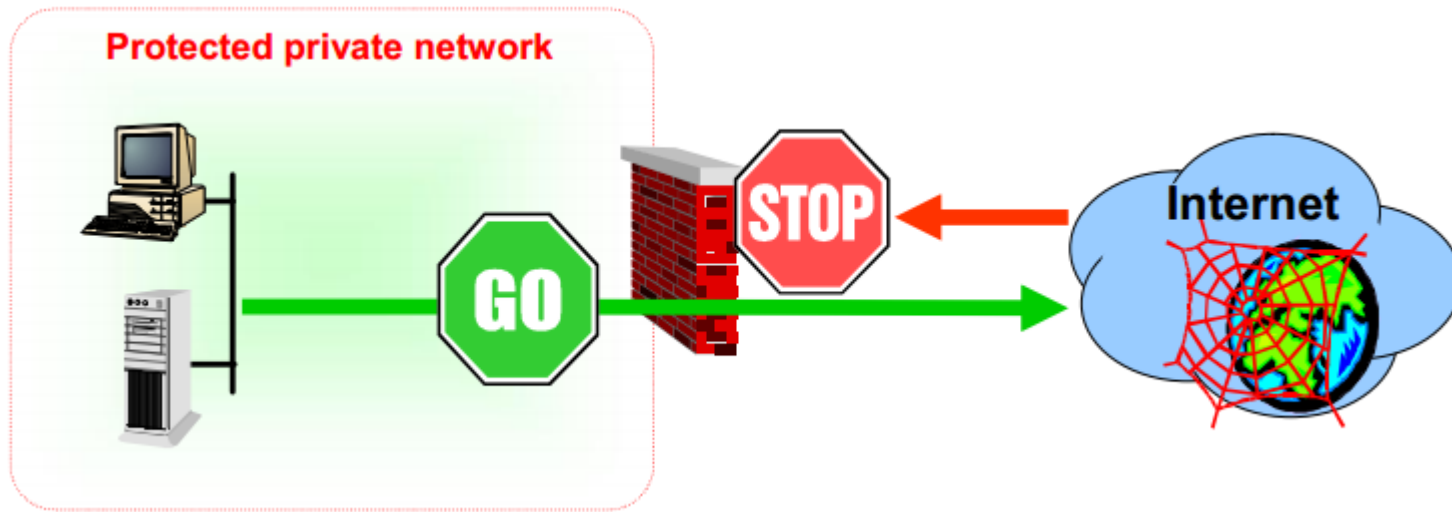
◆ *Circuit Level Gateways (CLG)*



МРЕЖОВО АДМИНИСТРИРАНЕ

Архитектури на защитните стени

- *Защитена локална (частна) мрежа*

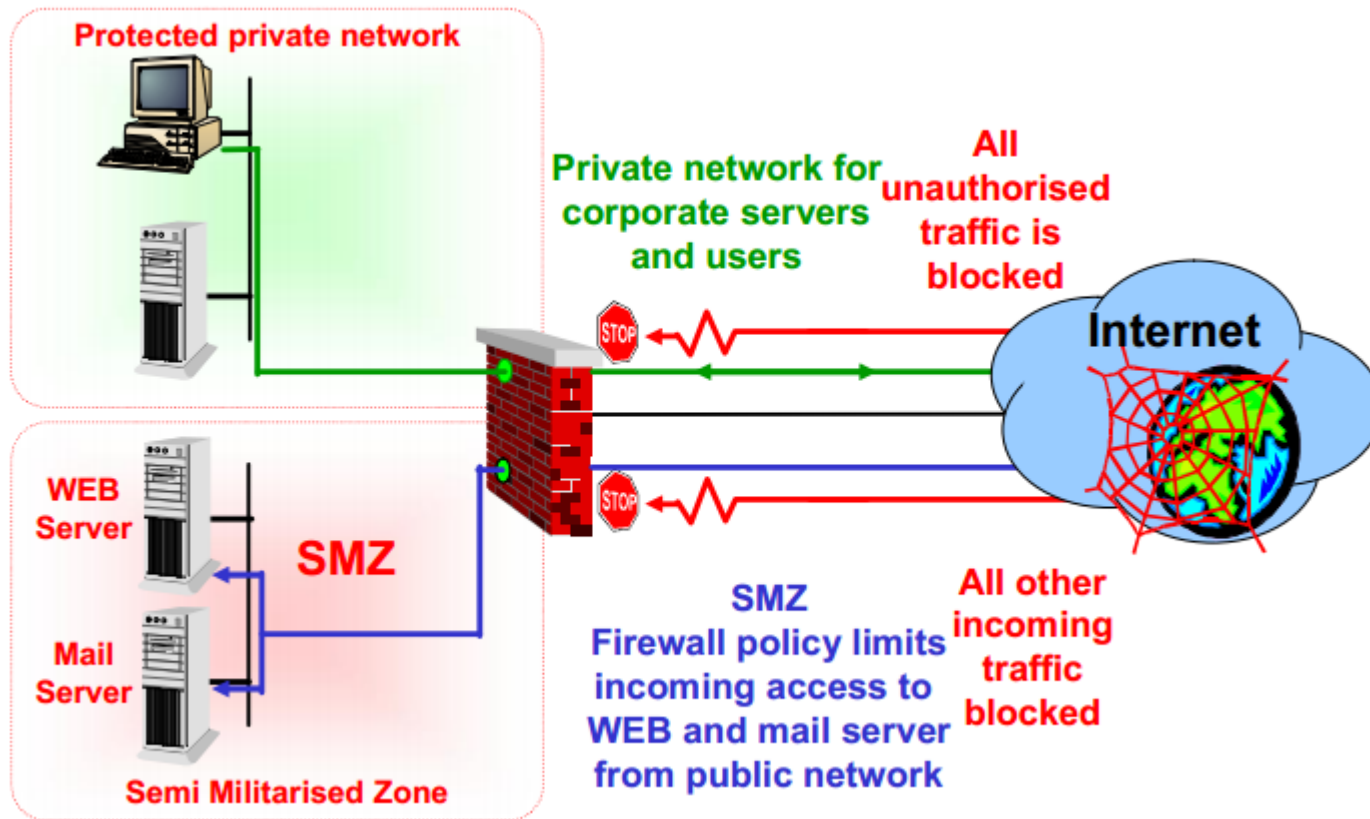


доц д-р инж. Росен Радков

МРЕЖОВО АДМИНИСТРИРАНЕ

Архитектури на защитните стени

- *Защитена локална (частна) мрежа и SMZ*

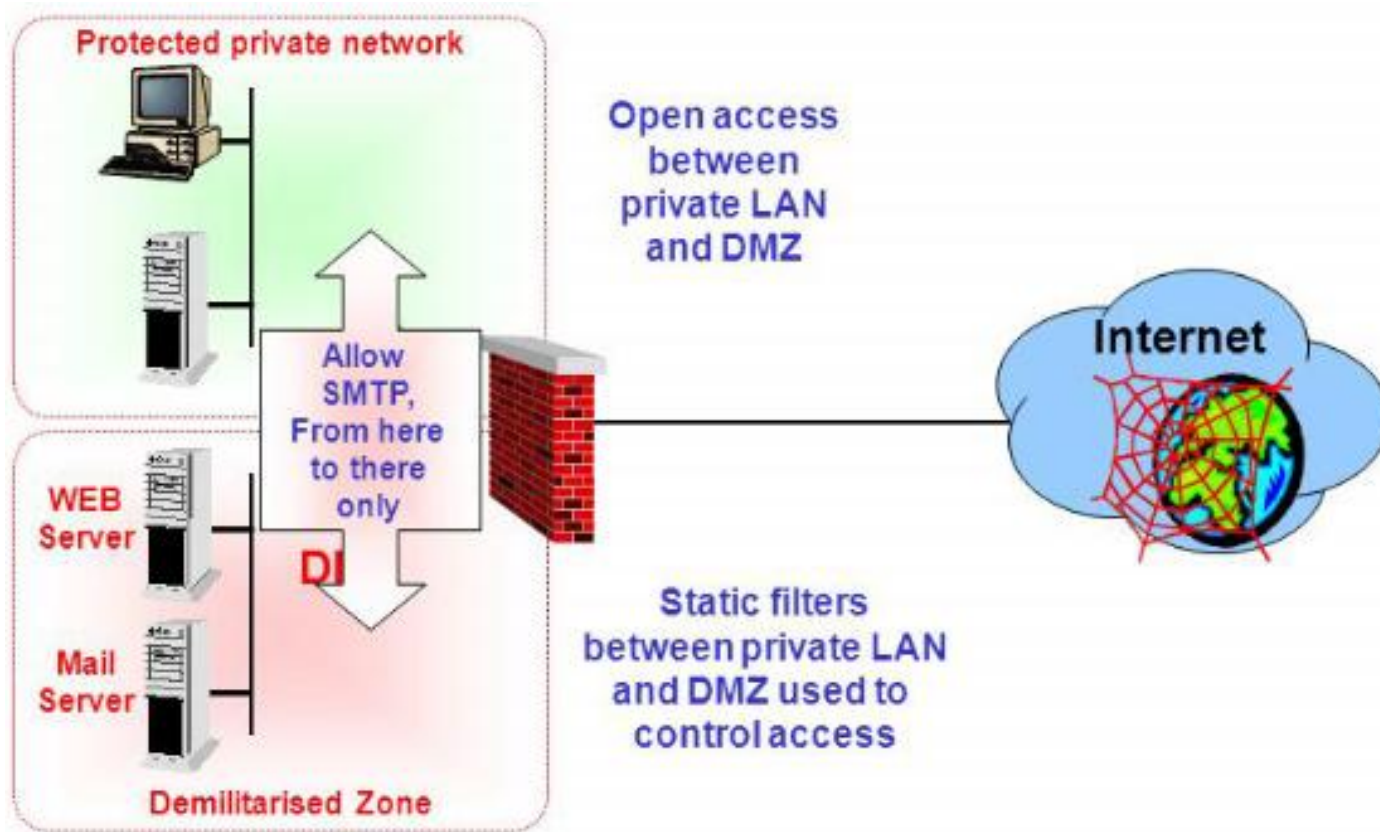


доц д-р инж. Росен Радков

МРЕЖОВО АДМИНИСТРИРАНЕ

Архитектури на защитните стени

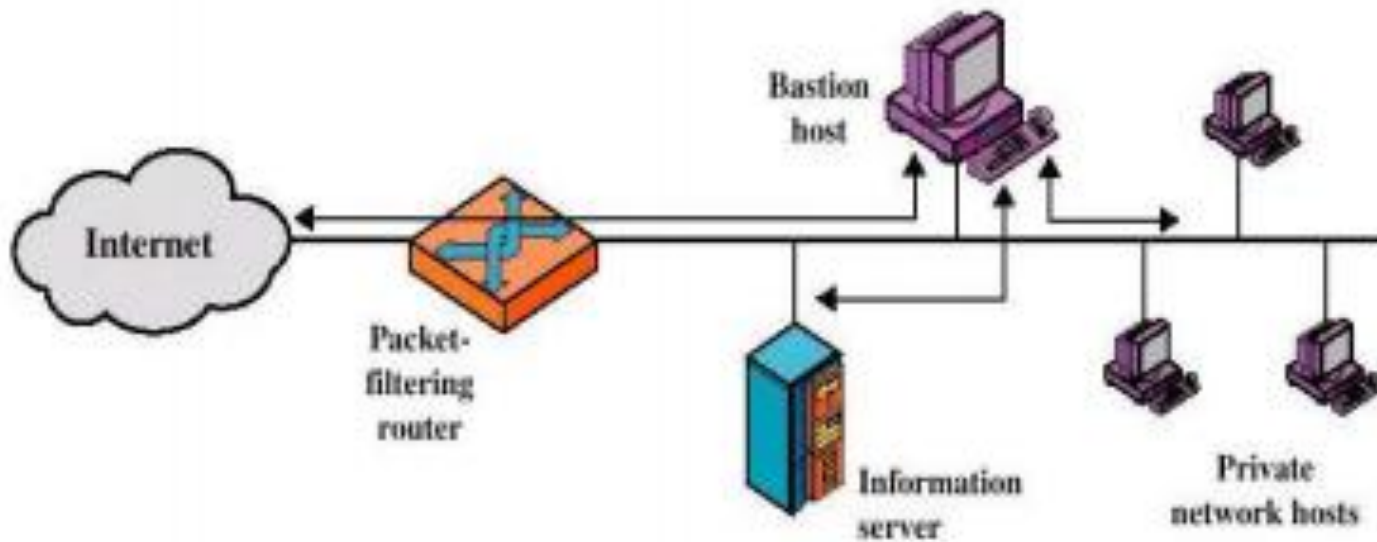
- *Защитена локална (частна) мрежа и DMZ*



МРЕЖОВО АДМИНИСТРИРАНЕ

Архитектури на защитните стени

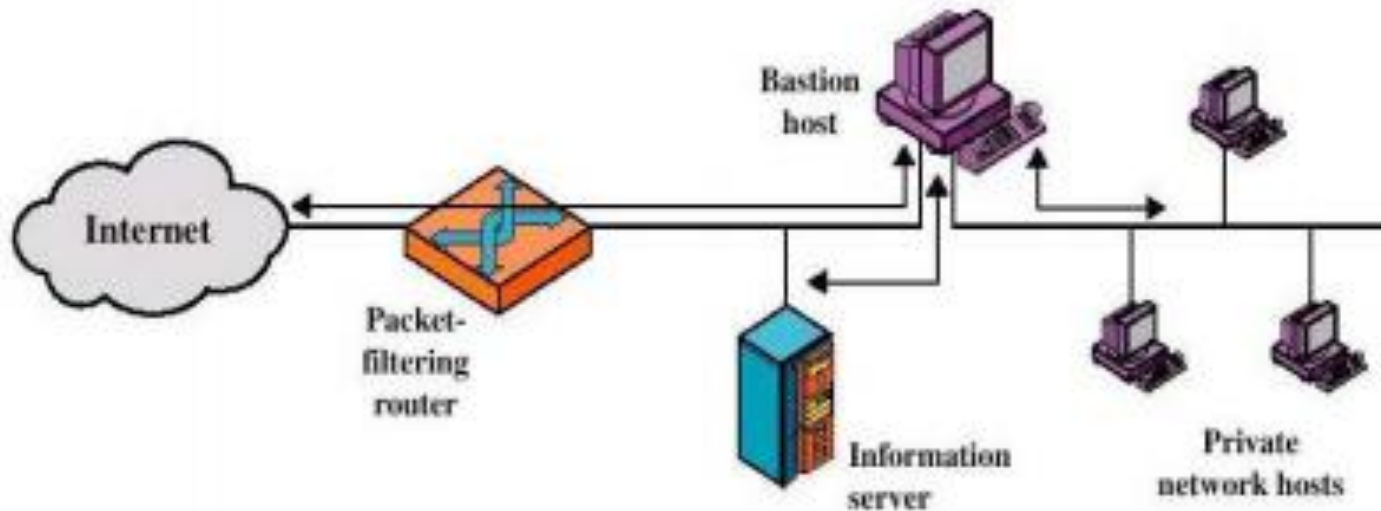
- *Screened Host Firewall System (Single-Homed Bastion Host)*



МРЕЖОВО АДМИНИСТРИРАНЕ

Архитектури на защитните стени

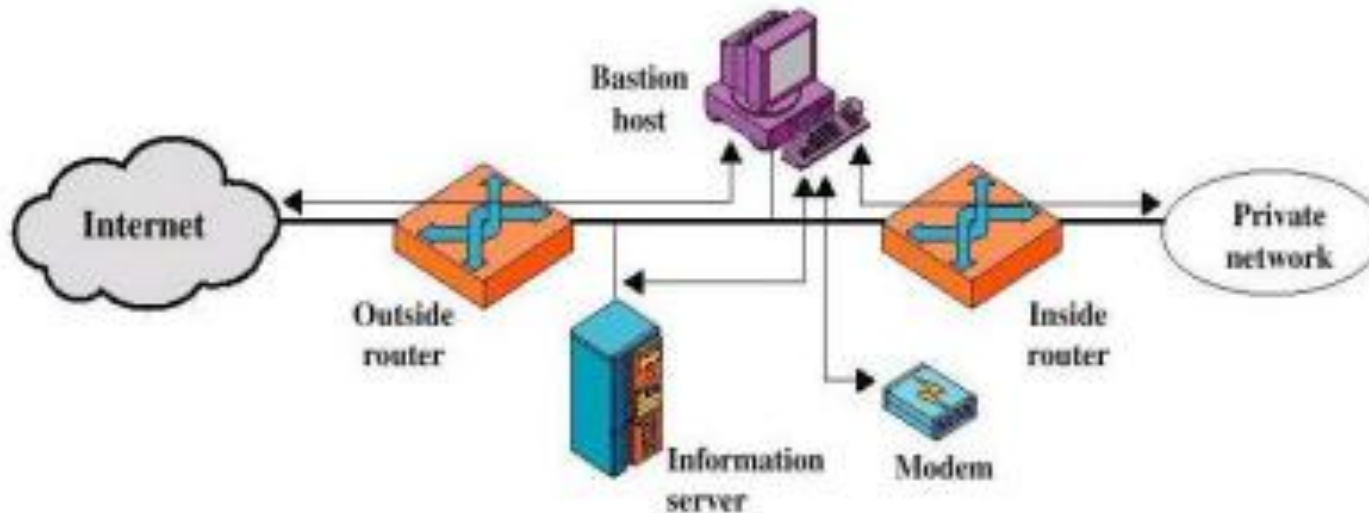
- *Screened Host Firewall System (Dual-Homed Bastion Host)*



МРЕЖОВО АДМИНИСТРИРАНЕ

Архитектури на защитните стени

➤ *Screened Subnet Firewall System*



МРЕЖОВО АДМИНИСТРИРАНЕ

Генерации защитни стени



1st Generation

Filtering Rules



2nd Generation



Filtering Rules
Stateful Inspection Table



Next Generation



Filtering Rules
Stateful Inspection Table
Deep Packet Inspection

доц д-р инж. Росен Радков

МРЕЖОВО АДМИНИСТРИРАНЕ

Генерации защитни стени



доц д-р инж. Росен Радков

МРЕЖОВО АДМИНИСТРИРАНЕ

Генерации защитни стени

Next Generation Firewall Technology



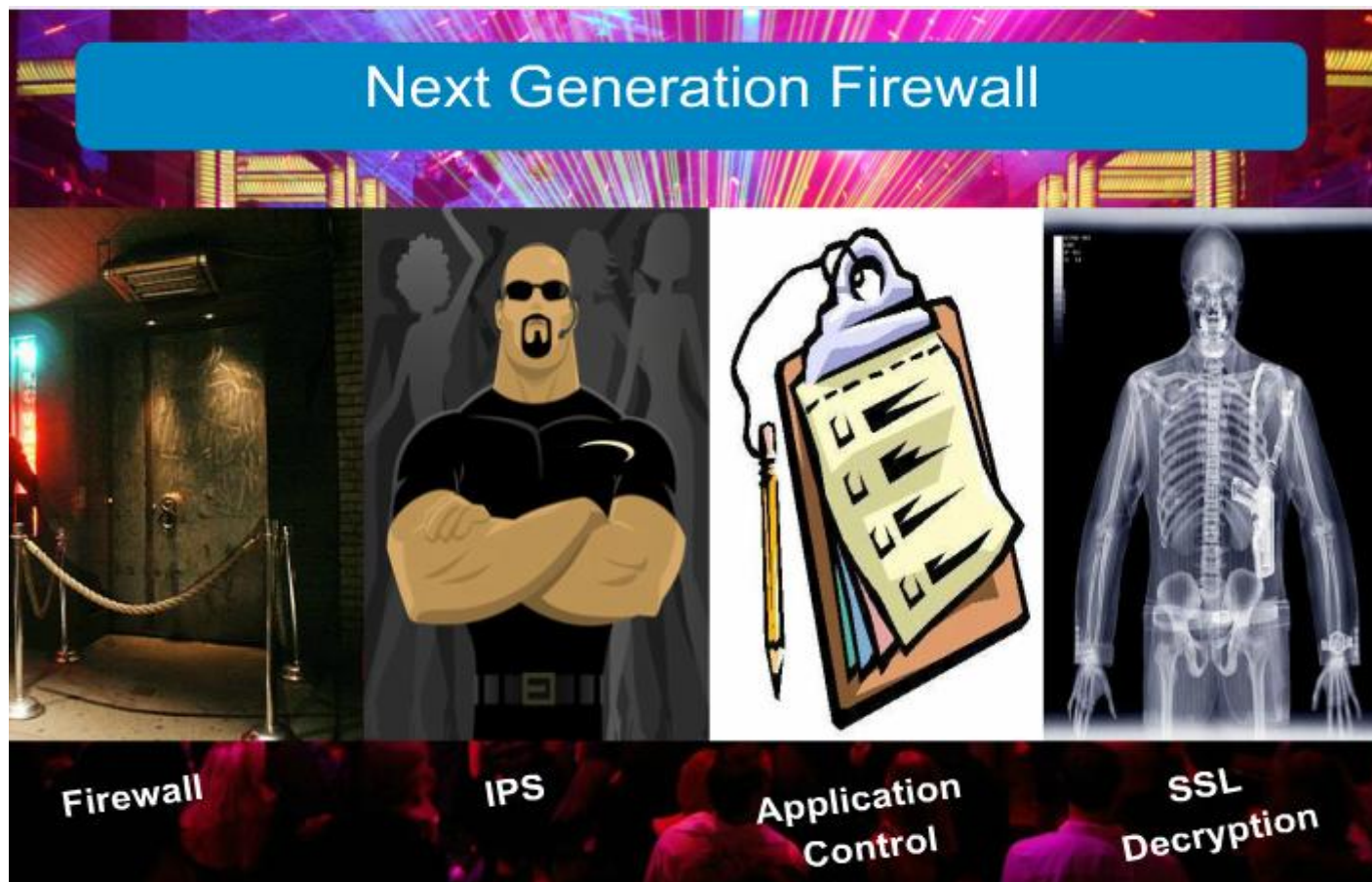
Deep Packet Inspection

1. **Stateful Packet Inspection**
2. **Intrusion Prevention**
 - The front-line network defense against application attacks
3. **Application Identification & Visualization**
 - Can't control what you can't see
4. **User Identification through Single Sign On (SSO)**
 - Correlate network traffic with users
5. **Application Control**
 - Granular control (Allow Facebook, Block Social Gaming)
6. **SSL Decryption**
 - Don't allow threats to tunnel through encrypted channels
7. **Threat Prevention**
 - Anti-X (Virus/Trojan/Malware)

доц д-р инж. Росен Радков

МРЕЖОВО АДМИНИСТРИРАНЕ

Генерации защитни стени



доц д-р инж. Росен Радков

МРЕЖОВО АДМИНИСТРИРАНЕ

Услуги предоставяни от NGFW

➤ Content Filter

Policy URL List Settings Custom List

Select Forbidden Categories

☐ Select all Categories

☒ 1. Violence/Hate/Racism	☐ 23. Government	☐ 45. Travel
☒ 2. Intimate Apparel/Swimsuit	☐ 24. Military	☐ 46. Vehicles
☒ 3. Nudism	☐ 25. Political/Advocacy Groups	☐ 47. Humor/Jokes
☒ 4. Pornography	☐ 26. Health	☐ 48. Multimedia
☒ 5. Weapons	☐ 27. Information Technology/Computers	☐ 49. Freeware/Software Downloads
☒ 6. Adult/Mature Content	☐ 28. Hacking/Proxy Avoidance Systems	☐ 50. Pay to Surf Sites
☒ 7. Cult/Occult	☐ 29. Search Engines and Portals	☐ 51. N/A
☒ 8. Drugs/Illegal Drugs	☐ 30. E-Mail	☐ 52. N/A
☒ 9. Illegal Skills/Questionable Skills	☐ 31. Web Communications	☐ 53. Kid Friendly
☒ 10. Sex Education	☐ 32. Job Search	☐ 54. Advertisement
☒ 11. Gambling	☐ 33. News and Media	☐ 55. Web Hosting
☒ 12. Alcohol/Tobacco	☐ 34. Personals and Dating	☐ 56. Other
☐ 13. Chat/Instant Messaging (IM)	☐ 35. Usenet News Groups	☐ 57. Internet Watch Foundation CAIC
☐ 14. Arts/Entertainment	☐ 36. Reference	☐ 58. Social Networking
☐ 15. Business and Economy	☐ 37. Religion	☐ 59. Malware
☐ 16. Abortion/Advocacy Groups	☐ 38. Shopping	☐ 60. N/A
☐ 17. Education	☐ 39. Internet Auctions	☐ 61. N/A
☐ 18. N/A	☐ 40. Real Estate	☐ 62. N/A
☐ 19. Cultural Institutions	☐ 41. Society and Lifestyle	☐ 63. N/A
☐ 20. Online Banking	☐ 42. N/A	☐ 64. Not Rated
☐ 21. Online Brokerage and Trading	☐ 43. Restaurants and Dining	
☐ 22. Games	☐ 44. Sports/Recreation	

If you believe that a Web site is rated incorrectly or you wish to submit a new URL, click [here](#).

доц д-р инж. Росен Радков

МРЕЖОВО АДМИНИСТРИРАНЕ

Услуги предоставяни от NGFW

➤ Intrusion Prevention;

#	Category ▾	Prevent	Detect
	ACTIVEX	Global	Global
	BACKDOOR	Global	Global
	BAD-FILES	Global	Global
	DB-ATTACKS	Global	Global
	DNS	Global	Global
	EXPLOIT	Global	Global
	EXPLOIT-KIT	Global	Global
	FTP	Global	Global
	ICMP	Global	Global
	IMAP	Global	Global
	INFO	Global	Global
	IoT-ATTACKS	Global	Global
	JAVA	Global	Global
	LDAP	Global	Global
	MEDIA-PLAYERS	Global	Global
	MISC	Global	Global
	NETBIOS	Global	Global
	OS-ATTACKS	Global	Global

доц д-р инж. Росен Радков

МРЕЖОВО АДМИНИСТРИРАНЕ

Услуги предоставяни от NGFW

➤ Geo-IP Filter

Security Services / **Geo-IP Filter**

☐ Block connections to/from countries listed in the table below

☒ All Connections ☐ Firewall Rule-based Connections

☐ Block all connections to public IPs if GeoIP DB is not downloaded

☐ Enable Logging

Countries

	Blocked	Country
☐		Afghanistan
☐		Aland Islands
☐		Albania
☐		Algeria
☐		American Samoa
☐		Andorra
☐		Angola
☐		Anguilla

доц д-р инж. Росен Радков

МРЕЖОВО АДМИНИСТРИРАНЕ

Услуги предоставяни от NGFW

- Gateway Anti-Virus;
- Anti-Spyware
- Botnet Filter

доц д-р инж. Росен Радков

МРЕЖОВО АДМИНИСТРИРАНЕ

Препоръки за настройка на защитни стени

- Защитната стена не трябва да бъде достъпна от Интернет за конфигуриране;
- Препоръчва се услуги като уеб и мейл да се пропускат през защитната стена, но да се пренасочват към специализирани AG филтри;
- Да се забрани *ping* за да се намали възможността за атаки чрез него;
- *Telnet* към всички вътрешни сървъри да бъде забранен;
- Компютърната мрежа да се организира на зони;
- Да се забрани входящ трафик, който е с адрес на източник съвпадащ с адреси от локалната(-ите) мрежа(-и).

МРЕЖОВО АДМИНИСТРИРАНЕ

БЛАГОДАРЯ ЗА ВНИМАНИЕТО!

доц д-р инж. Росен Радков